Lección 10 - Análisis, valoración y tratamiento del riesgo

Proporcionar las **herramientas** metodológicas para estudiar y resolver la **evaluación de riesgos del negocio, priorizando decisiones basadas en evidencia**.



Fuentes: NIST SP 800-30 Rev. 1 / NIST IR 8286 Rev. 1.

Gemini Notebook

El proceso: Calcular NO equivale a decidir

Identificación	¿Qué podría ocurrir?	Entregable: Escenarios
Análisis	¿Qué probabilidad e impacto tiene?	Entregable: Estimaciones y confianza
Valoración	¿Cómo se compara con las tolerancias?	Entregable: Prioridades
Tratamiento	¿Qué respuesta se elegirá?	Entregable: Acciones y residual esperado
Revisión	¿Se implementó y qué riesgo permanece?	Entregable: Evidencia de cierre



El cálculo aritmético es solo una entrada para el análisis; la decisión final requiere contexto empresarial. Calcular NO equivale a decidir.

Gemini Notebook

Escalas de valoración: PACÍFICO RETAIL (24 meses)

Probabilidad (P)	Impacto Financiero (I)
P1: 0 eventos / Condición ausente	**I1:** < 5 millones CLP
P2: 0 eventos / Condición presente	**I2:** 5 a < 20 millones CLP
P3: 1 evento	**I3:** 20 a < 50 millones CLP
P4: 2 a 9 eventos	**I4:** 50 a < 150 millones CLP
P5: 10+ eventos o escenario ocurriendo ahora	**I5:** ≥ 150 millones CLP



Regla del caso: Una vulnerabilidad técnica sin explotación observada NO significa que el escenario esté ocurriendo ahora (Nivel 5).

Gemini Notebook

Matriz de riesgo 5×5: Probabilidad × Impacto

	I1	I2	I3	I4	I5
P5	5	10	15	20	25
P4	4	8	12	16	20
P3	3	6	9	12	15
P2	2	4	6	8	10
P1	1	2	3	4	5

Bandas de Riesgo:

- Bajo (1-4)
- Moderado (5-9)
- Alto (10-16)
- Crítico (17-25)

Riesgo A: P2 × I5 = 10 (Alto).

Riesgo B: P5 × I2 = 10 (Alto).

El mismo puntaje puede representar escenarios diferentes y requerir tratamientos distintos.

Gemini Notebook

Anatomía de una valoración: Ejemplo R-01 resuelto



Toda asignación debe **justificarse** con un **dato o supuesto explícito**. Repetir el número no es una justificación.

Gemini Notebook

Analyst Workbench

La línea de tiempo del riesgo: Inherente vs. Residual

1. Riesgo Inherente

Estimación sin considerar ningún control.
(El punto de partida).

2. Residual Actual

Estimación con controles operando hoy y respaldados con evidencia comprobable.

3. Residual Esperado

Meta futura y condicionada. Solo se alcanza tras implementar y verificar un plan.



Proponer una acción escrita o un plan futuro **NO** reduce el riesgo residual actual.

Gemini Notebook

Analyst Workbench

Evaluar controles: Del papel a la realidad

1. **Existencia:** ¿Está documentado?
2. **Diseño:** Si funciona, ¿reduciría este escenario?
3. **Operación:** ¿Hay pruebas de que funciona rutinariamente?
4. **Efectividad:** ¿Reduce la P o la I de forma sostenida?

Declaración		Realidad Verificada
Respaldar	≠	Restauración completa probada, con tiempo de recuperación y pérdida de datos medidos
Parche declarado	≠	Parche verificado
MFA configurado	≠	Cobertura comprobada y pruebas de acceso permitido y rechazado

La reducción del riesgo residual actual requiere evidencia suficiente del diseño, la operación y la efectividad del control sobre el escenario evaluado.

Gemini Notebook

Incertidumbre: Calidad del dato vs. Gravedad del riesgo

Confianza
(Alta/Media/Baja)
depende de la calidad
de los datos.



Nivel del riesgo
(Probabilidad, impacto
y contexto).

¡Un riesgo crítico puede tener confianza baja!

Condición Provisional o Dato Faltante
(Ej. Parche por verificar)

- Si se confirma → Actualizar el escenario, valorar P e I y decidir el tratamiento según tolerancias, requisitos y urgencia
- Si se descarta → Registrar evidencia, revisar el supuesto y determinar si corresponde modificar la estimación o descartar el hallazgo

Validar una duda NO es mitigar. Los supuestos no se convierten en hechos por asignarles un número.

Gemini Notebook

Priorización: El contexto define el desempate

Priorizar = Comparar P × I con tolerancias, requisitos, urgencia, dependencias e incertidumbre

Filtros de PACÍFICO RETAIL:

- **Presupuesto límite:** $22 millones CLP.
- **Tolerancia (Urgencia):** Ninguna interrupción de la venta en línea puede superar 30 minutos durante noviembre.
- **Requisito innegociable:** Protección de datos personales obligatoria.
- **Factibilidad (Dependencia):** Cambios congelados entre 25 oct - 5 dic.

Un riesgo con producto 10 puede tener mayor prioridad que uno de 12 si incumple una tolerancia crítica del negocio. La decisión debe justificarse con evidencia y contexto.

Gemini Notebook

Tratamientos: Opciones y límites de la respuesta

1. Evitar

Eliminar la actividad raíz.

Ejemplo: Retirar un servicio que origina un riesgo intolerable.

⚠ **Límite:** Puede afectar el modelo de negocio.

2. Mitigar

Aplicar controles para reducir P o I.

Ejemplo: Implementar MFA para reducir probabilidad de acceso indebido.

⚠ **Límite:** Requiere validación y pruebas de efectividad.

3. Compartir / Transferir

Seguros o contratos de servicio.

Ejemplo: Contratar un seguro para compartir consecuencias financieras.

⚠ **Límite:** No elimina la responsabilidad legal ni organizacional.

4. Aceptar

Asumir el riesgo conscientemente.

Ejemplo: El propietario autoriza mantener un riesgo residual dentro de tolerancias.

⚠ **Límite:** Exige autorización del propietario, justificación y revisión. Nunca permite incumplir requisitos obligatorios.

Gemini Notebook

Hallazgos y decisiones: De la validación a la respuesta



Estado de los hallazgos	
H-01: Panel expuesto protegido únicamente mediante contraseña, sin MFA.	Estado: **Confirmado** (Se confirma la exposición, no se evidencia acceso indebido).
H-02: Pertenencia de IP.	Estado: Por confirmar.
H-03: Parche CartPlus.	Estado: Por verificar documentalmente.

Cuando la validación no puede completarse antes de una fecha crítica, se debe evaluar un control compensatorio **temporal**, documentado y verificable

Gemini Notebook

Diseño de un Plan Verificable (Ejemplo: VIÑA DEL ESTE)

Estado	Confirmado (Autenticación heredada habilitada).
Acción	Tratamiento: Mitigar. Deshabilitar protocolo heredado y exigir MFA.
Compensatorio	Alerta temporal de inicios de sesión inusuales.
Ejecutor / Propietario	TI implementa / Gerencia de Operaciones es dueña del riesgo.
Fecha / Dependencia	10 días hábiles. Requiere ventana de cambio.
Prueba de Cierre	Exportación de políticas, 100% cobertura, prueba positiva de autenticación con MFA y prueba negativa de acceso mediante autenticación heredada.
Residual Esperado	Condicional. P podría bajar de 2 a 1 tras verificación. Solo puede recalcularse como residual actual después de verificar la efectividad del control.

Gemini Notebook

Evidencia de cierre: Ticket cerrado ≠ Riesgo cerrado

Evidencia Débil	Evidencia Verificable
Captura de pantalla de una cuenta	MFA con cobertura 100% y pruebas positiva/negativa.
Mensaje de copia exitosa	Restauración con tiempo medido y acta.
Ticket marcado actualizado	Versión del parche y documentación técnica verificada.

Decisión sobre el riesgo residual

El verificador revisa la evidencia y comunica el resultado. → Se recalcula el riesgo residual con los controles efectivamente demostrados. → El propietario decide aceptar, tratar nuevamente o escalar según tolerancias, requisitos y autoridad. → Se documenta la decisión, fecha de revisión y condiciones de reapertura.

Gemini Notebook

Sensibilidad: Aislando variables para la decisión



Reglas de Sensibilidad

1. **Nunca cambiar dos variables a la vez.**
2. **¿Cambiar de banda modifica la prioridad?** No necesariamente. Si persiste el incumplimiento de un requisito obligatorio, el tratamiento sigue siendo necesario aunque disminuya el puntaje

Gemini Notebook

Cierre Ejecutivo y Errores a Evitar

Estructura del Cierre Ejecutivo
(Max 80 palabras)



Errores típicos a evitar

- [x] Bajar el residual actual sin pruebas de operación.
- [x] Usar el color bajo para aceptar romper un requisito.
- [x] Convertir dudas o supuestos en hechos confirmados.
- [x] Confundir la falta de confianza (dato) con la gravedad (impacto).

Gemini Notebook